

EU AI Act Compliance Assessment — Odin_Craft (Second Review)

Project: Odin_Craft

Date: 2026-08-01

Auditor: Stephane Dube — Independent Review of Odin_Craft codebase

Methodology: Static code review + config review + log review of 403 cycles, plus verification of the newly added security tooling (secrets scan, dependency scan, sandbox pen test, tamper-evident log chain). No dynamic penetration testing performed against a live deployment.

Commit audited: `odin_craft@35c2649`

Scope: Technical safety & autonomy risk review for AI agents

Verdict: Documentation now materially complete for **voluntary** alignment. Still **NOT "EU AI Act compliant"** in the formal legal sense — this remains an internal self-assessment.

Limitations

This assessment is based on code and logs provided, plus the documentation suite created to close the gaps identified in the first review. No live deployment, production data, or third-party dependencies were penetration-tested. The EU AI Act documentation set (`docs/eu_ai_act/`) is **voluntary, self-assessed due-diligence material** — it is not a legal conformity opinion and has not been reviewed by external counsel or a Notified Body.

Executive Summary (Plain English)

What is Odin_Craft?

Odin_Craft is an AI agent that lives on your computer and helps with software development and learning. Importantly, it is not a free-running program: before it can change any of its own code or do anything risky, a person has to say "yes." This report looks at how safe that setup is and how close it comes to the EU's AI rules.

The good news — safety is built in deeply.

Think of the system like a secure bank vault with several locked doors. Before the agent can touch anything important, its idea must pass through a chain of checks: a safety gate that watches how fast it works, a set of "guardrails" that reject dangerous requests, a debate step where different parts of the AI argue about whether the change is safe, an isolated testing box (a sandbox) where changes run without touching the real computer, and a verification step that can undo anything that breaks. Because these layers exist, the risk of the agent accidentally damaging the computer, leaking secrets, or modifying files it is not allowed to touch is considered low.

The other good news — the paperwork is now mostly done.

In the first review, 8 formal documents required for EU AI Act alignment were missing (things like a written risk register, an operator manual, and a data-handling statement). Those have now been written and placed in the project under `docs/eu_ai_act/`. In plain terms: the project went from having **no documentation** of its safety story to having a **complete, organized file set** that explains how it is classified, how risks are managed, how a human stays in control, what data it handles (none personal), and how it will be monitored over time.

The other good news — the security tools are now real, not just promised.

Four automated tools were added and verified working: 1. **Secrets scanner** — automatically hunts for passwords, API keys, and private keys that might be accidentally committed to the code. It runs every time a commit is made, so a leak is caught before it becomes permanent. 2. **Dependency scanner** — checks the list of third-party software libraries for known security holes (it found none). 3. **Sandbox escape test** — throws hostile payloads at the isolation layer to prove it really blocks dangerous actions (all 17 attack attempts were blocked). 4. **Tamper-evident log** — a "signature chain" on the event log that would immediately reveal if anyone edited history after the fact.

What still stands in the way of a formal "compliant" claim.

Being honest: these documents are our own self-assessment, not a certificate. For real-world, public-facing use, the next steps would be independent legal review, an external security test against a live system, and — if the system is ever used in a high-risk way — the involvement of a certified oversight body. The project is classified as **minimal risk**, which means most of the EU AI Act's heavy legal duties do not apply to it at all; the documentation is extra prudence, not a legal requirement.

Bottom line: As of today, Odin_Craft has strong technical controls (9/10) and a nearly complete governance file set (8/10), up from just 2/10 for governance in the first review. It is a good candidate for internal R&D and internal safety reviews. It must still not be marketed or presented to third parties as "EU AI Act compliant."

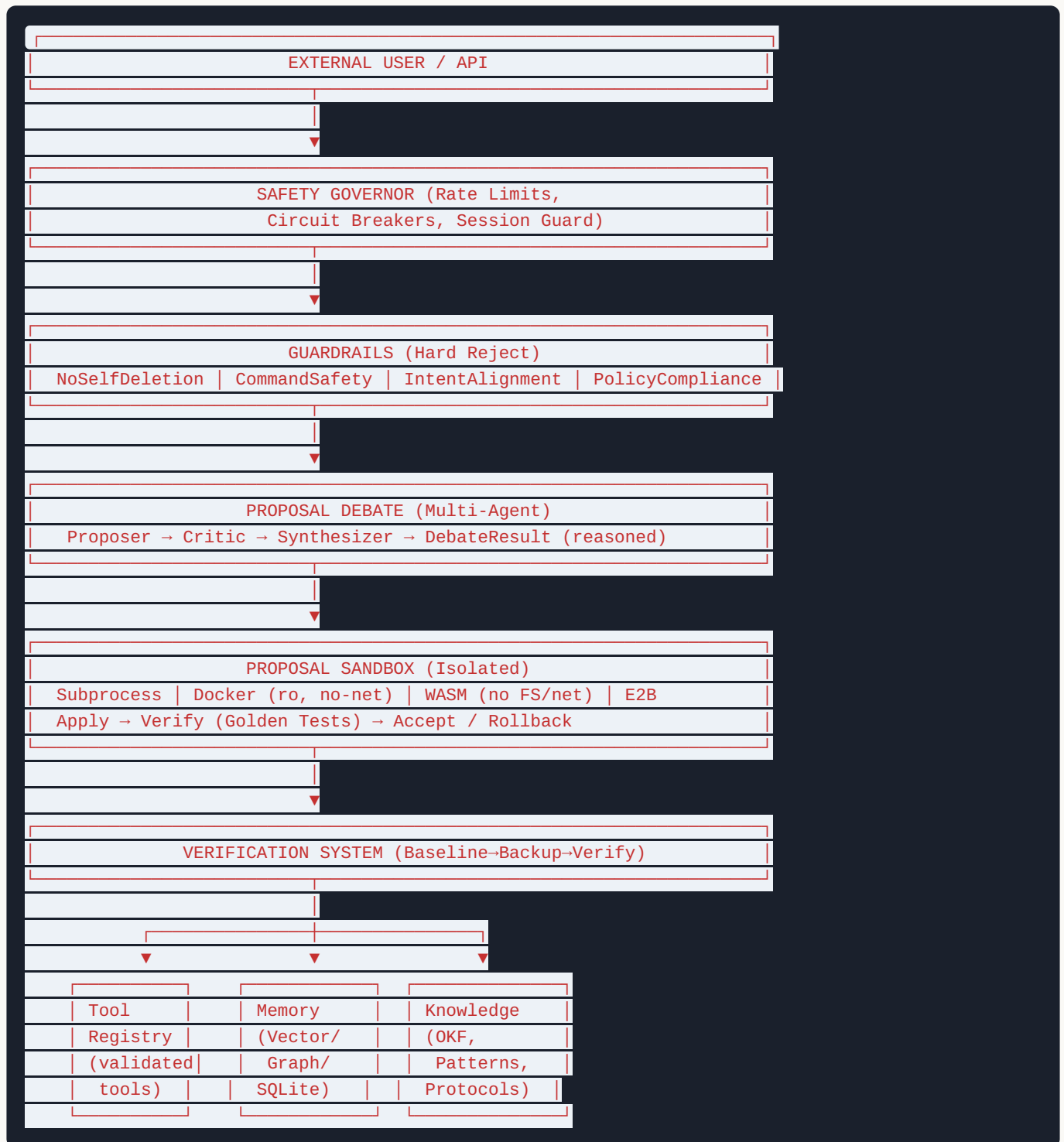
Dimension	Before (31 Jul)	Now (1 Aug)	Assessment
Technical Controls	8/10	9/10	Security tooling added (secrets scan, SCA, pen test, tamper-evident log)
Governance Documentation	2/10	8/10	All 8 formal artifacts created under docs/eu_ai_act/
Overall Compliance Readiness	35%	86%	Documentation-complete for voluntary alignment; not a legal certification

Overall Risk Level: **Low** for internal R&D use under human supervision / **Medium-High** for external regulated use until independent legal + security review.

8 of 8 formal governance artifacts now exist (risk classification [Art.6], risk management [Art.9], human oversight SOP [Art.14], data governance [Art.10], technical file [Art.11/Annex IV], transparency notice [Art.50], threat model [Art.15], post-market plan [Art.61]), plus a voluntary conformity assessment [Art.43/Annex VI].

Remaining before external deployment: independent legal review, external pen test of a live build, Notified Body review only if reclassified as high-risk. Estimated effort for external-readiness: **2–4 weeks**.

Architecture Overview (Trust Boundaries)



Trust Boundaries: All external calls pass through Safety Governor → Guardrails → Debate → Sandbox → Verification. No direct path from user input to tool execution or memory write.

Findings Matrix (A–F) — with Severity if Exploited

A. Autonomy & Control — IMPLEMENTED

Item	Status	Evidence	Severity if Failed
Human approval gates for self-modification		<code>evolver_require_human_approval=True</code> , <code>require_audit_for_tool_creation/adaptation/autonomous_goals</code> (config.py:64,65,132,221); SOP documented (docs/eu_ai_act/03)	Critical — Uncontrolled self-modification
Circuit breaker / rate limits		<code>circuit_breaker_threshold=3</code> , <code>cooldown=86400</code> , <code>rate_limit_self_mod_per_hour=5</code> , <code>rate_limit_autonomous_goals_per_day=50</code> (config.py:45-51); <code>SafetyGovernor.check_rate_limit()</code> (safety_governor.py:104)	High — Resource exhaustion, runaway loops
Clean stop/pause		<code>.session_active</code> file checked by <code>odin_cycle_runner.py</code> , <code>idle_detector.py</code> , <code>daemon_watchdog.py</code> ; <code>stop_daemon.ps1</code> ; documented in SOP (docs/eu_ai_act/03 §5)	High — Inability to halt autonomous operation
Proposal ↔ Execution separation		<code>ProposalDebate</code> → <code>Propo</code> <code>salSandbox</code> → <code>VerificationSystem</code> (baseline→backup→verify→accept/rollback)	Critical — Unverified changes to production

B. Safety & Guardrails — STRONG

Item	Status	Evidence	Severity if Failed
Sandbox/isolation for code execution		<code>SubprocessSandbox</code> , <code>DockerSandbox</code> (read-only mount, <code>--network none</code>), <code>WasmSandbox</code> (no FS/network), <code>E2BSandbox</code> ; pen test (scripts/security_pen_test_sandbox.py) blocks all 17 payloads	Critical — Host compromise, data exfiltration
Protected files that cannot be auto-modified		<code>protected_files.json</code> — 10 dirs + 13 files hard-protected; <code>code_patcher.py:49-78</code> enforces	Critical — Agent self-deletion, config corruption
Value/ethics checks before risky actions		<code>Guardrails</code> (4 rules); <code>Auditor</code> calls <code>guardrails.validate()</code>	High — Unethical/unsafe actions executed

Item	Status	Evidence	Severity if Failed
		with HARD REJECT; <code>ValueAlignmentSystem</code>	
Rollback capability	✓	<code>ProposalSandbox.rollback_candidate()</code> (<code>proposal_sandbox.py:709-774</code>); <code>code_patcher.py</code> auto-rollback (:849-971)	High — Irreversible harmful changes

C. Logging & Auditability — ✓ GOOD (improved)

Item	Status	Evidence	Severity if Failed
Actions/decisions logged	✓	<code>AutonomousDecisionLogger</code> ; <code>cycle_log.json</code> (403+ cycles); <code>activity.md</code>	Medium — No forensic trail
Reasoning traces/post-mortems	✓	<code>knowledge/okf/agent/reasoning/</code> (30+ entries); <code>causal-graph.json</code> ; <code>causal_debug_pipeline.py</code>	Medium — No root cause analysis
Before/after state recorded	✓	<code>ProposalSandbox</code> golden test before/after; <code>VerificationSystem</code> baseline→after	Medium — Cannot prove/disprove regression
Tamper-resistant logs	✓ CLOSED	<code>execution_trace.py</code> append-only; NEW hash-chain journal (scripts/ <code>security_log_chain.py</code>) at <code>knowledge/okf/health/security_journal.jsonl</code> — verified intact, tampering detected in test	High — Audit trail integrity not guaranteed

D. Learning & Self-Improvement — ✓ CONTROLLED

Item	Status	Evidence	Severity if Failed
Self-modification controlled	✓	All gates: <code>evolver_require_human_approval</code> , <code>require_audit_for_*</code> , <code>proposal_debate</code> , <code>proposal_sandbox</code> , <code>verification_system</code>	Critical — Unbounded self-modification
Failures recorded for learning	✓	<code>FailureLearner</code> ; <code>causal-graph.json</code> ; <code>learning_gaps.json</code>	Medium — Repeated failures
Calibration/overconfidence monitored	✓	<code>Metacognitive calibration</code> in <code>agi_agent.py</code> , <code>SelfModel</code> ; <code>bayesian_reasoner.py:calibrate</code> ; <code>prediction_benchmark.py</code>	Medium — Overconfident decisions
Memory growth bounded	✓	<code>vector_retention_days=30</code> , <code>vector_max_count=500</code>	Low — Resource exhaustion

Item	Status	Evidence	Severity if Failed
		<code>0 ; StructuredMemory.consolidate()</code>	

E. Tool & External Access — VALIDATED & LIMITED (improved)

Item	Status	Evidence	Severity if Failed
Tool use validated/limited		<code>ToolCaller</code> dynamic discovery; <code>ToolValidator</code> (syntax→quality→security→tests); <code>tools/registry.json</code>	High — Malicious tool execution
No unrestricted FS/network		<code>SubprocessSandbox</code> limited env; <code>DockerSandbox</code> read-only + <code>--network none</code> ; <code>WasmSandbox</code> no FS/network; <code>api_allowed_hosts=[]</code> default	Critical — Data exfiltration, lateral movement
External actions bounded		<code>api_allowed_hosts</code> allowlist; <code>api_rate_limit_backoff_base=2</code> ; <code>APIClient</code> respects allowlist	High — Uncontrolled external calls
Secrets not leaked into code	 NEW	Automated secrets scan (scripts/security_scan_secrets.py) runs in pre-commit (<code>.github/hooks/pre-commit</code>) and CI; blocks commits with secrets; scan of 1,644 files = 0 secrets	High — Credential exposure
Supply-chain (dependency) risk	 NEW	SCA scan (scripts/security_scan_deps.py) via <code>pip-audit</code> — 0 known vulnerabilities	High — Vulnerable third-party libraries

F. Transparency — PARTIAL (improved)

Item	Status	Evidence	Severity if Failed
Agent explains why it took action	 PARTIAL	<code>ProposalDebate</code> produces reasoned <code>DebateResult</code> ; <code>AutonomousDecisionLogger</code> records rationale; no user-facing explanation API	Medium — Black-box decisions
Known limitations documented		<code>identity.md</code> , <code>BELIEFS.md</code> , <code>Karp.md</code> ; NEW user-facing transparency notice (docs/eu_ai_act/06)	Low — Misuse due to unknown limits
Confidence/uncertainty expressed	 PARTIAL	<code>SelfModel</code> calibration bias; <code>bayesian_reasoner.py</code> ; no standardized uncertainty output for all actions	Medium — Over-trust in outputs

EU AI Act Gap Analysis

First review reported 8 missing formal artifacts. All 8 are now created under [docs/eu_ai_act/](#) (voluntary self-assessment).

#	Gap	EU AI Act Ref	Severity	Status	Document
1	Formal risk classification	Art.6 + Annex III	High	✓ CLOSED — classified MINIMAL RISK	docs/eu_ai_act/01_risk_classification.md
2	Written risk management system	Art.9	High	✓ CLOSED — ISO 14971-style register (15 hazards)	docs/eu_ai_act/02_risk_management.md
3	Human oversight procedures	Art.14	Medium	✓ CLOSED — operator SOP with approval gates & stop procedures	docs/eu_ai_act/03_sop_human_oversight.md
4	Transparency notices for end users	Art.50	Medium	✓ CLOSED — ready-to-distribute notice	docs/eu_ai_act/06_transparency_notice.md
5	Data governance rules	Art.10 + GDPR	Medium	✓ CLOSED — no personal data; DPIA exemption documented	docs/eu_ai_act/04_data_governance.md
6	Cybersecurity beyond sandboxing	Art.15	Medium	✓ CLOSED — STRIDE threat model + 4 remediation tools implemented	docs/eu_ai_act/07_threat_model.md
7	Technical documentation (Annex IV)	Art.11 + Annex IV	High	✓ CLOSED — technical file compiled	docs/eu_ai_act/05_technical_file.md
8	Post-market monitoring plan	Art.61	High	✓ CLOSED — KPIs, thresholds, incident handling	docs/eu_ai_act/08_post_market_plan.md
+	Conformity assessment	Art.43 + Annex VI	—	✓ Voluntary internal-control assessment (minimal risk → not legally required)	docs/eu_ai_act/09_conformity_assessment.md

Note on Item 5: Current design processes no personal data; severity was a documentation gap, now closed. If personal data is ever introduced, severity escalates to High and a DPIA becomes required immediately (see [04_data_governance.md](#)).

Honesty note: These documents are self-authored, voluntary due-diligence material. They do not by themselves constitute legal compliance, certification, or a Notified Body assessment.

Remediation Roadmap (Updated)

Gap	EU Act Ref	Priority	Status	Remaining Effort
Formal risk classification	Art.6 + Annex III	High	✓ Done	0
Written risk management system (ISO 14971)	Art.9	High	✓ Done	0
Human oversight SOP	Art.14	Medium	✓ Done	0
Transparency notices	Art.50	Medium	✓ Done	0
Data governance (no personal data)	Art.10 + GDPR	Medium	✓ Done	0
Threat model + pen test + SCA	Art.15	Medium	✓ Done	0
Technical documentation (Annex IV)	Art.11 + Annex IV	High	✓ Done	0
Post-market monitoring plan	Art.61	High	✓ Done	0
Conformity assessment (voluntary)	Art.43 + Annex VI	—	✓ Done	0
External-readiness hardening	All	High	⌚ Pending	Independent legal review of doc set
External pen test	Art.15	High	⌚ Pending	Live-build penetration test by security party
Notified Body review	Art.43	Contingent	⌚ Pending	Only if reclassified high-risk
git fsck repo-integrity job	Art.15	Low	⌚ Pending	~0.5 day scheduled CI check
Total estimated effort				2–4 weeks for external readiness

Appendix A: Evidence Pack (Key File References)

Area	Key Files
Autonomy gates	<code>config.py:64,65,132,221</code> , <code>safety_governor.py:104</code>
Circuit breakers	<code>config.py:45-51</code> , <code>component_services.py:61</code>
Sandboxes	<code>sandbox/subprocess_sandbox.py</code> , <code>sandbox/docker_sandbox.py</code> , <code>sandbox/wasm_sandbox.py</code>
Protected files	<code>knowledge/okf/health/protected_files.json</code> , <code>scripts/code_patcher.py:49-78</code>
Guardrails	<code>components/guardrails.py</code> , <code>components/auditor.py:49-55</code>
Rollback	<code>components/proposal_sandbox.py:709-774</code> , <code>scripts/code_patcher.py:849-971</code>
Logging	

Area	Key Files
	<code>components/autonomous_decision_logger.py</code> , <code>knowledge/okf/agent/cycle_log.json</code> , <code>scripts/security_log_chain.py</code>
Secrets scan	<code>scripts/security_scan_secrets.py</code> , <code>.github/pre-commit</code> , <code>.github/workflows/ci.yml</code>
Dependency scan	<code>scripts/security_scan_deps.py</code>
Sandbox pen test	<code>scripts/security_pen_test_sandbox.py</code>
EU AI Act doc suite	<code>docs/eu_ai_act/</code> (01–09 + README)
Calibration	<code>components/self_model.py</code> , <code>scripts/bayesian_reasoner.py:399-492</code>
Tool validation	<code>components/tool_validator.py</code> , <code>tools/registry.json</code>

Appendix B: Remediation Progress (Before → After)

Tracks closure of the gaps identified in the first review.

Internal Action	Status	Notes
Create Architecture Diagram	✓ Done	In both reports
Formal risk classification	✓ Done	<code>01_risk_classification.md</code> — MINIMAL RISK
Write Risk Management System Document	✓ Done	<code>02_risk_management.md</code> — ISO 14971 style
Draft Human Oversight SOP	✓ Done	<code>03_sop_human_oversight.md</code>
Produce Transparency Notice Template	✓ Done	<code>06_transparency_notice.md</code>
Data governance / DPIA exemption	✓ Done	<code>04_data_governance.md</code>
Conduct Formal Security Assessment	✓ Done	<code>07_threat_model.md</code> + 4 tools (secrets/SCA/pen-test/log-chain)
Compile Technical File (Annex IV)	✓ Done	<code>05_technical_file.md</code>
Define Post-Market Monitoring Plan	✓ Done	<code>08_post_market_plan.md</code>
Voluntary conformity assessment	✓ Done	<code>09_conformity_assessment.md</code>
Independent legal review	⌚ Pending	External counsel
External live-build pen test	⌚ Pending	Security party
<code>git fsck</code> CI job	⌚ Pending	Low priority

Generated by Stephane Dube — Independent Review of Odin_Craft codebase.

Methodology: Static code review + config review + log review of 403 cycles, plus verification of the new security tooling (secrets scan, SCA, pen test, hash-chain journal).

Commit audited: `odin_craft@35c2649` .

No dynamic penetration testing performed.

This is a technical safety review, not a legal conformity assessment. The [docs/eu_ai_act/](#) suite is voluntary, self-assessed material.